

□ Laboratory Exercise: Kerberos Protocol Deep Dive and Security Analysis (Week 07)

Module Focus: Key Distribution Protocols and Real-World Security Flaws

Learning Objectives

Upon completion of this lab, students will be able to:

- **Analyze** the functional and security differences between Kerberos Versions 4 and 5.
 - **Explain** the purpose and significance of Kerberos Pre-authentication.
 - **Evaluate** a real-world attack scenario targeting Kerberos authentication.
 - **Compare** Kerberos to modern web authentication schemes (OAuth/OpenID Connect).
-

Part I: Case Study Analysis – The Offline Password Guessing Attack (Kerberos v4)

This case study focuses on one of the critical security flaws in Kerberos v4 that necessitated the introduction of **Pre-authentication** in Kerberos v5.

Scenario Background

In the original Kerberos v4 protocol, when a client requested a session ticket from the Authentication Server (AS), the server would respond with a message containing two parts:

1. The **Ticket-Granting Ticket (TGT)** (encrypted with the TGS's secret key).
2. The **Session Key** (encrypted with the client's secret key, \$K_C\$, which is derived from the user's password hash).

Case Study: The "No Pre-authentication" Attack

An attacker, Charlie, is a network eavesdropper. Charlie observes a client, Alice, send her initial request to the AS.

1. Charlie intercepts the **AS Reply** message sent back to Alice.
2. Crucially, this message (which contains the Session Key encrypted with \$K_C\$) is **always sent**, regardless of whether Alice is a legitimate user or not, and regardless of whether Charlie even knows her password.
3. Charlie now has a ciphertext block encrypted with Alice's password hash (\$K_C\$).
4. Charlie takes the ciphertext **offline** and uses a dictionary or brute-force attack (called a "**Kerberoasting**" type of attack on v4) to guess Alice's password. If the guess is correct, the resulting key will correctly decrypt the Session Key.

Analysis Questions (To be answered by the student)

1. **Vulnerability Identification:** What specific design feature of Kerberos v4 (related to the AS Reply message) made this offline attack possible?

2. **Mitigation in v5:** How did the introduction of **Pre-authentication** in Kerberos v5 solve this specific vulnerability? What information must the client now send to the AS *before* the AS issues the reply?
3. **Security Impact:** Why is an **offline attack** significantly more dangerous than an **online attack** (where an attacker attempts to guess a password by repeatedly submitting it to the login screen)?

Part II: Technical Deep Dive – Kerberos v5 Improvements

Utilize the slide "**DIFFERENCES BETWEEN VERSIONS 4 AND 5**" (likely Slide 32) as the primary resource for this section.

Guided Research Task

For each of the following v5 improvements, research and explain the "**Why**"—the specific limitation or security risk in v4 that the change addressed.

Kerberos v5 Improvement	Why was this change necessary? (Explain the v4 limitation)
Encryption Algorithm Flexibility	(E.g., Moving from fixed DES to supporting AES, 3DES, etc.)
ASN.1 and Message Byte Ordering	(The impact of platform dependence on interoperability.)
Inter-Realm Authentication	(How did v5 enhance security and scalability for multi-domain networks?)
PCBC Encryption Removal	(Why was the PCBC mode considered risky and how did v5 address it?)

Recommended Link for Reference

- **Article on Kerberos Security Flaws and Fixes:**

 Difference Between Kerberos Version 4 and Kerberos Version 5 (GeeksforGeeks)

(Focus on the section detailing the technical deficiencies.)

Part III: Synthesis and Modern Context

Discussion and Extension Questions

1. **Real-World Application:** Kerberos v5 is the core authentication protocol for **Microsoft Active Directory**. Briefly explain how the **Inter-Realm Authentication**

feature is crucial for large organizations with multiple domains (e.g., a corporate forest).

2. **Protocols Comparison:** Kerberos is primarily used for **Internal Network Authentication (SSO)**. However, modern authentication on the Internet uses protocols like **OAuth 2.0** and **OpenID Connect**.
 - What is the **fundamental difference** in the goal of Kerberos (authentication) versus the goal of OAuth 2.0 (authorization)?
 - Do you believe the core principles of Kerberos (using a trusted third party, KDC/AS) are still relevant in decentralized modern applications? Why or why not?
3. **Critical Thinking:** An attacker has compromised a single **Kerberos Realm** master key. Based on your understanding of Kerberos architecture, what is the maximum potential damage they could inflict on the entire network? (Consider the principle of "shared secrets.")